

TwinaForms Salesforce Code Analyzer ISV Response

Date: 2026-06-05

Scope: current force-app source for the released TwinaForms managed package 0.10.0.5. The focused AppExchange security scan was run with:

```
sf code-analyzer run --workspace force-app --target force-app --rule-selector AppExchange --output-file security-reports\code-analyzer\isv-submission-2026-06-05\appexchange-security-focused.json --output-file security-reports\code-analyzer\isv-submission-2026-06-05\appexchange-security-focused.html --severity-threshold 1 --view table
```

Tool versions from the JSON report: Salesforce Code Analyzer 0.33.0, PMD engine 0.29.0. The --severity-threshold 1 flag gates the command exit code; it does not filter reported findings. All severities were still reported, and the focused AppExchange scan reported no Critical or High findings.

Output files:

- security-reports/code-analyzer/isv-submission-2026-06-05/appexchange-security-focused.html
- security-reports/code-analyzer/isv-submission-2026-06-05/appexchange-security-focused.json

The focused AppExchange scan reported 28 moderate findings. No critical or high AppExchange security findings were reported in the focused scan. The AppExchange ruleset's CRUD/FLS (ApexCRUDViolation), sharing (ApexSharingViolations), and SOQL-injection (ApexSOQLInjection) rules were included in the scan and produced zero findings.

Summary

The findings are keyword-based false positives caused by package terminology such as signature, token, and key. The reported values are not passwords, OAuth refresh tokens, API secrets, private key material, or user credentials.

`NativeFormsBootstrapV2Signer.SIGNATURE\_ALGORITHM`

Rule: AvoidHardcodedCredentialsInFieldDecls

Classification: False positive.

SIGNATURE_ALGORITHM stores the public algorithm label HMAC-SHA256. This is not the HMAC secret, tenant bearer secret, OAuth token, or any private credential. The secret material used for signing is not hard-coded in Apex.

`NativeFormsDesignerController.placedRowSignature`

Rule: AvoidHardcodedCredentialsInVarAssign

Classification: False positive.

placedRowSignature is a Boolean layout variable used by the form designer to detect whether a signature input element was placed inside a repeat group. It stores only true or false and does not contain cryptographic

signatures, passwords, tokens, or private keys.

`NativeFormsDesignerController.objectToken`

Rules: AvoidHardcodedCredentialsInVarDecls, AvoidHardcodedCredentialsInVarAssign

Classification: False positive.

objectToken is a sanitized Salesforce object-name fragment used to build a readable page-layout import action name. It is derived from an object API name, normalized to alphanumeric/underscore characters, and used only as a label/name component. It is not an authentication token and does not grant access to data.

`NativeFormsPublisher.signatureHtml`

Rules: AvoidHardcodedCredentialsInVarDecls, AvoidHardcodedCredentialsInVarAssign

Classification: False positive.

signatureHtml is generated browser HTML for the published form signature capture field. It contains markup such as a canvas, clear button, help text, and validation feedback container. It does not contain cryptographic signatures, secrets, credentials, or private key material.

`NativeForms\_Config\_\_c.Captcha\_Site\_Key\_\_c`

Rule: ProtectSensitiveData

Classification: Accepted public value.

This field stores a Google reCAPTCHA site key. reCAPTCHA site keys are intended to be public and are rendered to browser pages. The corresponding CAPTCHA secret key is not stored in Salesforce.

`NativeForms\_Config\_\_c.Enable\_Pro\_SF\_Secret\_Code\_Auth\_\_c`

Rule: ProtectSensitiveData

Classification: False positive.

This field is a Boolean feature flag. It stores only true or false. The phrase Secret Code is the product feature name and does not mean the field contains a secret value.

`NF\_Form\_\_c.NF\_Key\_\_c`

Rule: ProtectSensitiveData

Classification: False positive.

This field stores a stable generated form identifier used by the package to identify a form. It is not a password, OAuth token, API secret, or bearer credential.

`NF\_Form\_Action\_\_c.Command\_Key\_\_c`

Rule: ProtectSensitiveData

Classification: False positive.

This field stores a generated command identifier used to map configured prefill or submit actions. It is a design-time/runtime mapping key and does not authenticate users or grant access by itself.

`NF\_Form\_Element\_\_c.Field\_Key\_\_c`

Rule: ProtectSensitiveData

Classification: False positive.

This field stores a generated field identifier used to map submitted JSON values to form elements. It is not secret and does not provide access to Salesforce data.

`NF\_Form\_Publication\_\_c.Publication\_Status\_\_c`

Rule: ProtectSensitiveData

Classification: False positive.

This restricted picklist stores publication job state values such as pending, success, or failed. It contains no secret or credential material.

`NF\_Form\_Publication\_\_c.Publication\_Type\_\_c`

Rule: ProtectSensitiveData

Classification: False positive.

This restricted picklist stores the publication operation type, such as publish, republish, unpublish, or register-only. It is not an authentication value.

`NF\_Form\_Version\_\_c.Publish\_Token\_\_c`

Rule: ProtectSensitiveData

Classification: Accepted public per-form capability token.

This value gates the public prefill and submit endpoints for one published form. The form it protects is already a public form, and the token grants no Salesforce login, no cross-form access, no cross-tenant access, no package service access, and no tenant administration access. AWS stores only a hash of the publish token with the server-side form policy.

`NF\_Submission\_Log\_Key\_\_c.Key\_Version\_\_c`

Rule: ProtectSensitiveData

Classification: False positive.

This field stores a version label for submission-log cryptography configuration, such as v2. It is metadata about the key format/version and does not contain key material.

`NF\_Submission\_Log\_Key\_\_c.Public\_Key\_\_c`

Rule: ProtectSensitiveData

Classification: Accepted public cryptographic material.

This field stores a public cryptographic key. Public keys are designed to be shared and are not secret. This field does not contain private key material.

Reviewer Disposition

All focused AppExchange findings are documented as false positives or accepted public values. No finding in this focused scan indicates exposed credentials, exposed OAuth secrets, missing tenant authentication, SOQL injection, XSS, CSRF, or insecure endpoint usage.